VULNHUB DROOPY: v0.2

Capture-the-Flag / Vulnerability Assessment Report

Victim IP	192.168.31.174
Victim hostname	droopy.lan
Observed platform	Ubuntu Linux; Drupal 7 website
Scope	Supplied screenshots and report workbook
Outcome	Remote code execution workflow and root-level local privilege escalation shown in evidence

Prepared from the supplied Droopy v0.2 evidence. Non-target IP addresses and unrelated hostnames are redacted in embedded screenshots. No personal email address or personal password is included.

For authorized, isolated lab use only.

1. Executive Summary

The supplied evidence identifies the victim as **192.168.31.174** (hostname **droopy.lan**). Nmap reports TCP/80 open and identifies Apache httpd 2.4.7 on Ubuntu with a Drupal 7 generator banner. A Metasploit screenshot shows the Drupal exploit workflow and a Meterpreter session opening. A later screenshot shows `37292.c` compiled and executed on the target, after which the terminal reports `uid=0(root)`.

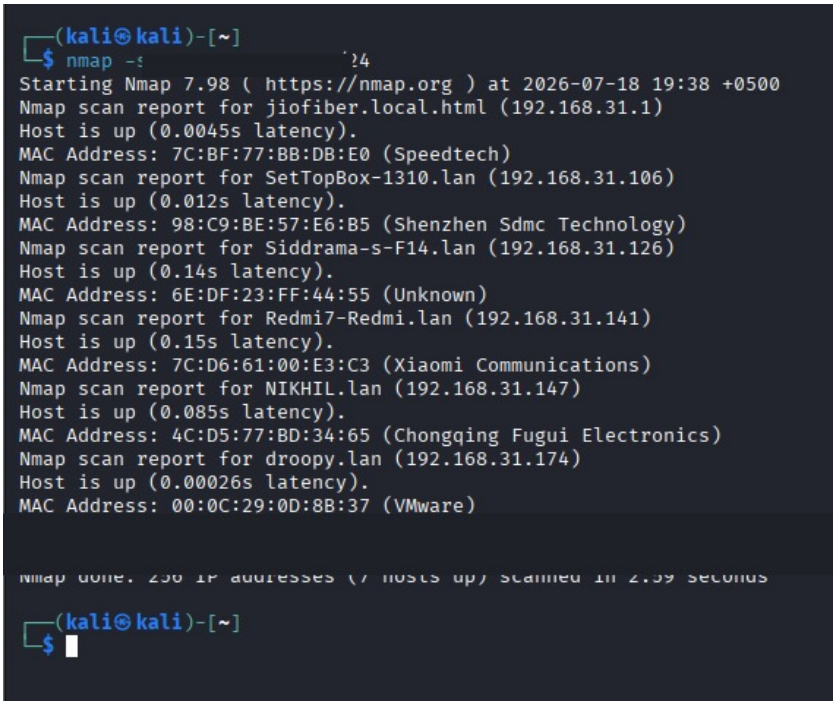
Evidence limitations: the workbook lists FTP on TCP/21 (vsftpd 2.3.4), but the Nmap screenshot reports 999 closed TCP ports and only TCP/80 open in the scanned top 1,000 ports. FTP is not treated as a verified finding. The local exploit filename is consistent with Dirty COW / CVE-2016-5195, but the source code and kernel version are not visible, so the attribution is not independently verified.

2. Scope and Evidence Handling

This report uses the five supplied screenshots and report workbook. Screenshots are attached to the relevant findings. Unrelated device hostnames/IPs and the attacker/listener IP are redacted; the victim IP and hostname remain visible. No live re-test was performed.

3. Reconnaissance — Host Discovery

The discovery evidence identifies **droopy.lan (192.168.31.174)** as the victim host. Other network hosts are redacted.



Evidence 1. Host discovery; unrelated network devices and addresses redacted.

PoC

```
nmap -sn 192.168.31.0/24
```

Observed result: the screenshot identifies 192.168.31.174 as a live host. The command above is a reproducible example for an authorized lab subnet.

4. Finding 1 — Drupal Web Application / Remote Code Execution

Field	Details
Victim / port	192.168.31.174 / TCP 80
Service	HTTP — Apache httpd 2.4.7 (Ubuntu)
Application	Drupal 7 generator banner observed
Severity	Critical impact in the lab; remote code execution workflow shown
Reference	Drupalgeddon2 / CVE-2018-7600 is consistent with the Metasploit module shown; patch level not independently verified
Evidence	Exploit module run and Meterpreter session shown in supplied screenshot

Description

Nmap identifies a Drupal 7 site on TCP/80. The supplied Metasploit terminal screenshot shows the `multi/http/drupal_drupageddon` module configured for the victim and a Meterpreter session opening, supporting a successful remote-code-execution workflow in this lab.

PoC table — reproduce only in an isolated authorized VM

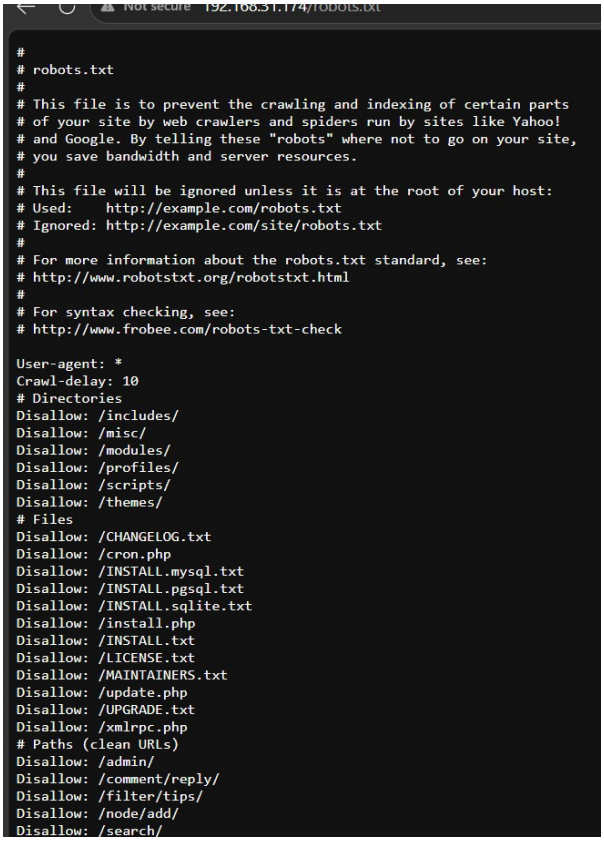
```
nmap -n -sV -sC -O 192.168.31.174
msfconsole
search drupal drupageddon
use exploit/multi/http/drupal_drupageddon
set RHOSTS 192.168.31.174
set RPORT 80
set TARGETURI /
show options
# Configure a suitable lab payload/listener, then run.
run
```



Evidence 2. Nmap shows TCP/80 open, Apache 2.4.7 (Ubuntu), and Drupal 7.

robots.txt path disclosure

The public robots.txt lists Drupal paths and installation-related filenames. robots.txt is not an access-control mechanism; verify that listed paths do not expose sensitive files.



Evidence 3. robots.txt lists Drupal paths and installation-related filenames.

5. Finding 2 — Local Privilege Escalation to Root

Field	Details
Affected host	192.168.31.174
Component	Linux local privilege boundary / kernel
Evidence	37292.c uploaded to /tmp, compiled and executed; output reports uid=0(root)
Likely reference	Exploit-DB 37292 is commonly associated with Dirty COW / CVE-2016-5195; screenshot alone does not verify source contents or kernel vulnerability
Severity	Critical if the kernel is vulnerable and attacker already has local code execution

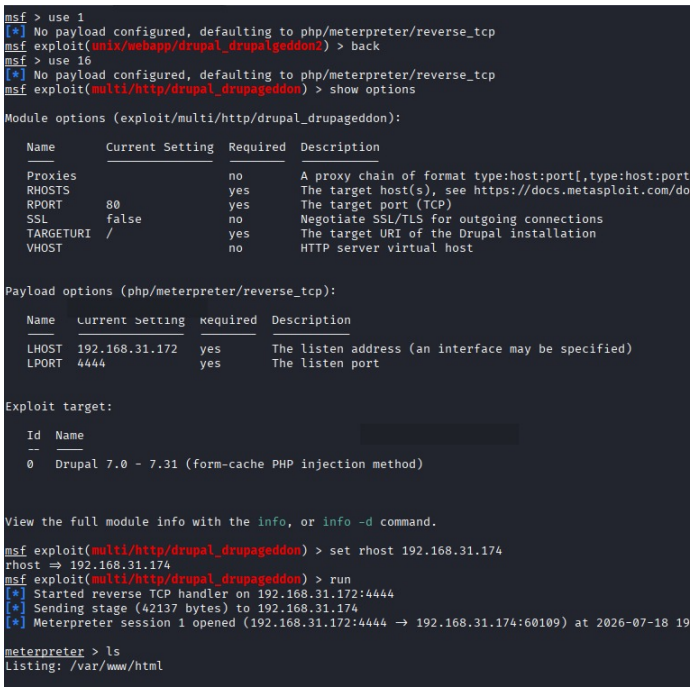
Description

The terminal evidence shows a C source file named `37292.c` uploaded to `/tmp`, compiled as `shell`, and executed. The result includes `uid=0(root) gid=0(root)`. The exploit's exact CVE attribution is not fully proven by the screenshot.

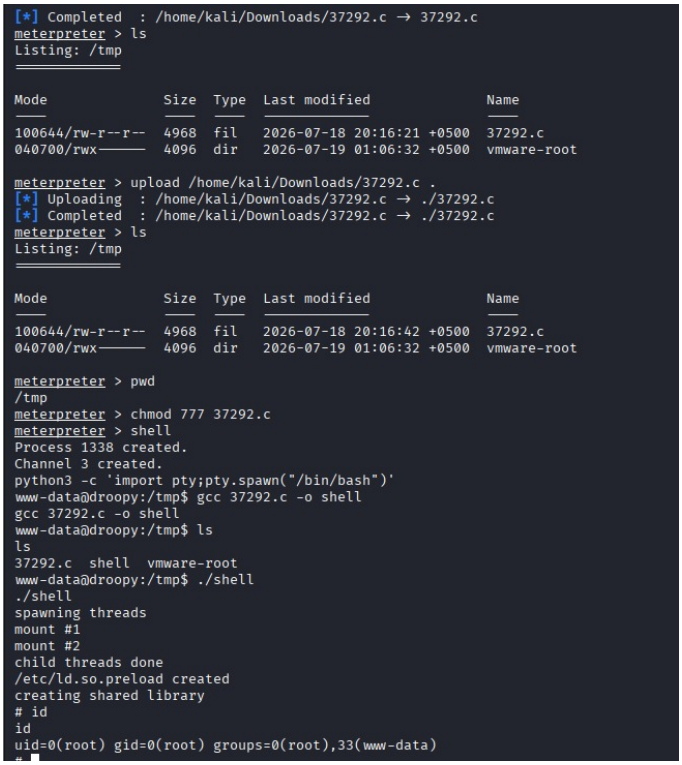
PoC — evidence reproduction summary

```
cd /tmp
gcc 37292.c -o shell
./shell
id
```

Observed result: the screenshot reports uid=0(root). Only run privilege-escalation code in a disposable lab VM you own or are authorized to test.



Evidence 4. Drupal exploit workflow and Meterpreter session; attacker/listener IP redacted.



Evidence 5. Local exploit compilation/execution and root UID output.

6. Port-by-Port Evidence Table

Port	Service / evidence	Assessment
80/tcp	HTTP; Apache 2.4.7 (Ubuntu); Drupal 7 banner	Verified open. Drupal RCE workflow shown.
21/tcp	Workbook lists FTP / vsftpd 2.3.4	Not verified by screenshot; not reported as open.
Other TCP	Nmap states 999 closed TCP ports in top-1,000 scan	No other open ports evidenced in supplied scan.

7. Remediation Recommendations

Drupal/web application
• Upgrade Drupal to a currently supported release and apply all vendor security updates.
• Remove obsolete modules/themes and restrict administrative/installation paths.
• Do not rely on robots.txt to protect sensitive paths.
• Re-test after patching and verify the vulnerable request path no longer works.

Linux privilege escalation
• Patch the OS kernel and reboot into a supported patched kernel.
• Remove compilers/development tools from production where not required.
• Review temporary-directory execution policy and monitor for unexpected binaries or root-owned files.

HTTP exposure
• Keep Apache and the operating system supported and patched.
• Minimize unnecessary server banners/content and expose only required services through a firewall.

8. Limitations and Conclusion

This report is based only on the supplied screenshots and workbook; no live re-test was performed. FTP/21 is not a confirmed open port. The Dirty COW/CVE-2016-5195 attribution is a likely match, not independently verified. The evidence supports a Drupal exploitation workflow on TCP/80 and subsequent root-level access in the lab. Patch Drupal and the host kernel, then perform a fresh scan and regression test.